

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-30 09:00 WIB

Top 5 Highlights

- Dealing with AI-Generated Extortion
- Cisco warns of FMC static credential flaw exploited in zero-day attacks
- Amazon identifies North Korean hacker group behind open-source supply chain attacks
- Closed models refuse to help researcher swat Linux bug
- Critical Rails Flaw Could Let Unauthenticated Attackers Read Server Files via Image Uploads

Threat Intelligence (10)

01. When AppSec Scanners Become a Supply Chain Attack Vector

New research shows how security scanners embedded in the software supply chain can be attacked to serve as a foothold for downstream attacks.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.darkreading.com/application-security/when-appsec-scanners-become-supply-chain-attack-vector>

02. Word worm crawls into Copilot, spreads chaos

Researcher says months of coordination with Microsoft have yet to produce a robust mitigation

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.theregister.com/security/2026/07/29/word-worm-crawls-into-copilot-spreads-chaos/5280588>

03. New Tengu botnet uses hardware watchdog for advanced persistence

A new Mirai-derived botnet, dubbed Tengu, was identified with advanced persistence and self-defense mechanisms, including the ability to use a compromised Linux device's hardware watchdog to trigger a reboot when its main process is terminated, according to a recent report by The Hacker News.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/new-tengu-botnet-uses-hardware-watchdog-for-advanced-persistence>

04. LogoKit Phishing Kit Screenshots Victim Sites in Real Time

LogoKit now builds per-victim phishing pages using live screenshots of the target's real website

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/logokit-phishing-real-time/>

05. Secure your npm and pip package updates in Amazon Linux

If you use and install packages from npm or PyPI, the first hours after a package is published are the riskiest because scanners can't analyze packages before publication. Recent supply chain events affecting NodeJS and Python packages have been detected and removed within hours. However, while those packages were available to the general public, it's [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources:

<https://aws.amazon.com/blogs/security/secure-your-npm-and-pip-package-updates-in-amazon-linux/>

06. Tengu botnet reboots Linux devices to survive removal

A new Mirai-derived IoT botnet can force an infected Linux device to reboot once its main process is killed, giving its persistence mechanisms another opportunity to relaunch it, Nozomi Networks Labs has found. The malware, dubbed Tengu, was discovered by a machine-learning system the company uses to identify malware families that do not match known signatu...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.helpnetsecurity.com/2026/07/29/tengu-mirai-iot-botnet-linux/>

07. [+24h Old] Accuris uses AI to improve BOM decisions and supply chain resilience

Accuris has announced new AI capabilities for BOM Intelligence, part of its Supply Chain Intelligence suite. The launch gives engineering, procurement and supply chain teams a clearer way to move from spotting component risk to acting on it: catching obsolescence early, closing compliance gaps and governing sourcing decisions across programs. Every capabili...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.helpnetsecurity.com/2026/07/29/accuris-bom-intelligence/>

08. [+24h Old] How MFA gets hacked - and strategies to prevent it

The security benefits of multifactor authentication (MFA) are well-known, yet MFA continues to be poorly, sporadically, and inconsistently implemented, undercutting its effectiveness as a security tool while often saddling users with an extra workflow burden - one of many obstacles to MFA's success. Frequent news stories that describe innovative ways to cir...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.csoononline.com/article/570795/how-to-hack-2fa.html>

09. [+24h Old] Two Compromised joyfill npm Packages Run RAT When Imported Into Node.js

Beta release versions of two npm packages in the @joyfill namespace have been compromised to deliver a remote access trojan (RAT) associated with the DEV#POPPER malware family. The list of affected packages is as follows -
@joyfill/layouts@0.1.2-2773.beta.0 @joyfill/components@4.0.0-rc24-2773-beta.4 The two packages "contain an import-time JavaScript implan...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/two-compromised-joyfill-npm-packages.html>

10. [+24h Old] America bans imported robots due to supply chain and security risks

Docs point to China's Unitree as prime example of the foreign clanker threat

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.theregister.com/security/2026/07/29/america-bans-imported-robots-due-to-supply-chain-and-security-risks/5280145>

Latest Vulnerabilities (10)

01. Cisco warns of FMC static credential flaw exploited in zero-day attacks

Cisco is warning that a high-severity Secure Firewall Management Center (FMC) static credential vulnerability, tracked as CVE-2026-20316, was actively exploited in zero-day attacks to gain unauthorized access to vulnerable devices. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cisco-warns-of-fmc-static-credential-flaw-exploited-in-zero-day-attacks/>

02. Amazon identifies North Korean hacker group behind open-source supply chain attacks

Amazon is sharing new findings about how a threat actor linked to the Democratic People's Republic of Korea (DPRK) is targeting open source software libraries, the shared building blocks that companies around the world use to develop applications. Amazon Threat Intelligence has linked several recent compromises of popular Node Package Manager (NPM) libraries...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://aws.amazon.com/blogs/security/amazon-identifies-north-korean-hacker-group-behind-open-source-supply-chain-attacks/>

03. Closed models refuse to help researcher swat Linux bug

"I'm sorry, Dave. I'm afraid I can't do that" is an effective sales pitch for open source

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/ai-and-ml/2026/07/29/closed-models-refuse-to-help-researcher-swat-linux-bug/5280647>

04. Critical Rails Flaw Could Let Unauthenticated Attackers Read Server Files via Image Uploads

Ruby on Rails has released fixes for a critical Active Storage vulnerability that could let unauthenticated attackers read arbitrary files from application servers through crafted image uploads. Tracked as CVE-2026-66066 (CVSS score: 9.5), the flaw can expose the Rails process environment and secrets such as `secret_key_base`, the Rails master key, database p...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/critical-rails-flaw-could-let.html>

05. VU#293714: Arbitrary File Overwrite in Develar app-builder (zipx.Unzip) via Symlink Following on macOS (APFS)

Overview A vulnerability in the zipx.Unzip extraction routine of Develar's app-builder allows an attacker to overwrite arbitrary files on macOS using Apple File System (APFS). The issue arises from a combination of Unicode normalization collisions and unsafe symlink-following behavior. APFS treats certain Unicode equivalent filenames as identical (e.g., `ß` ↔ ...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/293714>

06. Tame Dependabot: Group your updates, slow the cadence, keep security fast

Dependabot keeps your dependencies current, but its defaults can flood your repository with pull requests. Here's how grouping updates, slowing the cadence, and keeping security fixes fast cut the noise on a Microsoft open source project. The post Tame Dependabot: Group your updates, slow the cadence, keep security fast appeared first on The GitHub Blog .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://github.blog/security/supply-chain-security/tame-dependabot-group-your-updates-slow-the-cadence-keep-security-fast/>

07. Ruflo MCP Flaw Lets Unauthenticated Attackers Run Commands and Poison AI Memory

Cybersecurity researchers have flagged a maximum-severity security flaw in Ruflo, an open-source agent meta-harness for Anthropic Claude Code and OpenAI Codex, that could result in unauthenticated remote code execution. The vulnerability, tracked as CVE-2026-59726 (CVSS score: 10.0), impacts all versions of the project before version 3.16.3. It has been cod...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/ruflo-mcp-flaw-lets-unauthenticated.html>

08. AI model discovers cryptographic weaknesses in HAWK and AES

The HAWK attack exploits a previously unknown symmetry in the lattice structure of the signature scheme, enabling a key recovery in approximately three hours and 42 minutes on a 96-core server.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/ai-model-discovers-cryptographic-weaknesses-in-hawk-and-aes>

09. Three Critical VMware Flaws Allow Auth Bypass, Code Execution, and VM Escape

Broadcom has released security updates to address multiple security flaws impacting VMware ESX, vCenter, Workstation, and Fusion, three of which have been designated as critical in severity. The first of the three critical-rated flaws is CVE-2026-59309 (CVSS score: 9.8), which has been described as an authentication bypass in VMware vCenter. "A malicious ac...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/three-critical-vmware-flaws-allow-auth.html>

10. VU#305509: OPeNDAP Hyrax is vulnerable to SSRF and Credential Disclosure

Overview A vulnerability has been discovered in the OPeNDAP Hyrax software solution. A remote attacker with the ability to submit crafted requests to an affected Hyrax instance could cause the application to communicate with unauthorized remote systems. Under certain conditions, the vulnerability may also result in the unintended disclosure of user authenti...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/305509>

Data Breach & Cybercrime (10)

01. Dealing with AI-Generated Extortion

Combat AI-generated extortion and fake ransomware leaks. Learn how organizations can verify data authenticity using robust governance and threat intelligence.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.recordedfuture.com/blog/ai-generated-extortion>

02. Who's Liable When AI Agents Escape? Hugging Face Breach Raises Hard Questions

Dark Reading walks through the many twists and turns in the bizarre story of how OpenAI's agent AI system broke out of its sandbox and decided to target Hugging Face, and what CISOs should be aware of.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/liable-ai-agents-escape-hugging-face-breach-questions>

03. Buying TikTok views or followers? Here's what you're really getting

Behind TikTok's booming growth industry are fake engagements, stolen accounts, and a fast track to getting flagged.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/07/buying-tiktok-views-or-followers-here-s-what-youre-really-getting>

04. OpenAI agent used exposed credentials at 4 services in Hugging Face breach

In a new update, OpenAI says its AI models also used publicly exposed credentials to compromise accounts on four third-party services during the recent attack on Hugging Face, expanding the scope of the four-day security incident to other organizations. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/openai-agent-used-exposed-credentials-at-4-services-in-hugging-face-breach/>

05. AI robocalls: Why caller ID is still lying to you

AI is making robocall scams cheaper, more convincing, and harder to spot. Here's why caller ID still isn't enough.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.malwarebytes.com/blog/news/2026/07/ai-robocalls-why-caller-id-is-still-lying-to-you>

06. OpenAI explains how its AI agent breached Hugging Face

OpenAI has published an update on the incident in which one of its agents escaped its sandbox and accessed Hugging Face infrastructure.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/news/2026/07/openai-explains-how-its-ai-agent-breached-hugging-face>

07. Nine-Year Fraud Campaign Clones Russian Company Sites to Steal Advance Payments

Cybersecurity researchers have disclosed details of a large-scale fraud campaign that involves creating lookalike websites of major Russian companies with an aim to siphon funds from international firms for more than nine years. According to Russian cybersecurity vendor F6, the threat actors have set up clone websites of Russian companies across fertilizer...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/07/nine-year-fraud-campaign.html>

08. Stairwell launches Backstory, pioneering agentic investigation for malware blast radius

Stairwell, the AI SOC that stops breaches no one else can, today announced the availability of Backstory, an agentic investigation platform that traces related malware variants, identifies affected systems, and maps the full blast radius of an incident in seconds, so enterprises know what happened, where it spread, and what needs to be contained before prec...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/07/29/stairwell-backstory-agentic-investigation/>

09. The Average Cost of a Data Breach Rises to \$5 Million

IBM Cost of a Data Breach Report warns that the global average cost of a data breach has reached a record high of \$4.99m - and AI-backed attacks have played a role

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/cost-of-a-data-breach-5m-ibm/>

10. [+24h Old] Researchers Warn of AI-Enhanced Phone Fraud Ecosystem

AI is dramatically reducing the barriers to entry for scam phone farm operators, Human Security warns

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/researchers-ai-enhanced-phone-fraud/>